RAPPORT D'INVESTIGATION FORENSIQUE

DÉTECTION ET ANALYSE D'UNE COMPROMISSIONSUR UN SERVEUR LINUX

I. Description de l'incident

1. Contexte et découverte

Le serveur internal-server, un serveur Ubuntu 22.04 LTS avec l'adresse IP (192.168.253.200) exposant un service SSH sur le réseau interne, a fait l'objet d'une compromission complète dans le cadre d'une simulation d'attaque. Les Signaux d'alerte ayant déclenché l'investigation sont des Multiples tentatives de connexion SSH échouées détectées par Fail2Ban, la création d'un compte utilisateur non autorisé ("backup"), une connexion SSH réussie du compte "testuser" depuis une IP suspecte, une activité réseau inhabituelle (connexion sortante sur port non standard) et des Modifications suspectes des fichiers de logs système.

2. Nature de la Compromission

L'attaque est une intrusion externe avec élévation de privilèges. Son vecteur initial est Brute-force SSH du compte testuser ce qui a donné un contrôle total du système (Root). L'analyse forensique a révélé une compromission complète suivant un scénario d'attaque sophistiqué en 7 phases distinctes, de la reconnaissance initiale jusqu'aux tentatives de couverture des traces.

II. MÉTHODOLOGIE

L'investigation forensique a été menée en cinq phases pour garantir la validité juridique des preuves collectées :

- Préservation : Snapshot du système et collecte des preuves volatiles
- Acquisition : Copie des logs et artefacts avec calcul de hashes (SHA-256)
- Analyse : Corrélation multi-sources des événements
- Reconstitution : Timeline détaillée de la compromission
- Documentation : Rapport forensique et IOC

Les sources principales de preuves analysées sont :

- /var/log/auth.log - Authentifications SSH
- /var/log/audit/audit.log - Audit système
- /var/log/sudo.log - Commandes privilégiées
- /var/log/fail2ban.log - Détection intrusion
- /var/log/ufw.log - Activité pare-feu

III. Analyse des preuves extraites

1. Brute-Force SSH

Source : /var/log/auth.log
Analyse :

- Pattern d'attaque : Brute-force par dictionnaire
- IP source : 192.168.100.20 (machine attaquante identifiée)
- Tentatives totales : 13 échecs avant succès
- Compte compromis : testuser

- Credentials découverts : testuser: Test@User123

2. Élévation de Privilèges

Source : /var/log/audit/audit.log et /var/log/sudo.log

Analyse

• Utilisateur : testuser (uid=1002, auid=1002)
• Élévation : uid=1002 → euid=0 (root)
• Commande : /bin/bash (shell root obtenu)
• Le champ "auid=1002" prouve que c'est testuser qui a exécuté cette commande.

3. Création du Backdoor

Source : auditd (création compte)

Analyse :

• Compte créé : backup (uid=1003)
• Créateur : root (uid=0) MAIS auid=1002 (testuser après élévation)
• Privilèges : Membre du groupe sudo
• Impact : Backdoor permanent avec accès root

IV. Chronologie détaillée

La reconstitution basée sur la corrélation de toutes les sources de preuves :

Temps	**Evénement**
T+00:00	PHASE 1 : RECONNAISSANCE : • Scan Nmap depuis 192.168.100.20 • Identification du service SSH (port 22)
T+00:12	PHASE 2 : BRUTE-FORCE (Tentative 1) : • Cible : compte "admin" • Résultat : ÉCHEC (10 tentatives)
T+00:42	PHASE 3 : ACCÈS INITIAL : • Connexion SSH réussie : testuser@192.168.100.10 • Mot de passe découvert : password123
T+01:10	PHASE 4 : ÉLÉVATION DE PRIVILÈGES : • Commande : sudo /bin/bash • Résultat : Accès root obtenu
T+01 :20	PHASE 5 : CRÉATION BACKDOOR • Compte créé : backup (uid=1003, groupe=sudo) • Clés SSH configurées pour persistance
T+01:28	PHASE 6 : EXFILTRATION + C2 • Données exfiltrées : /etc/shadow, /etc/passwd • Connexion C2 : 192.168.100.20:4444
T+01:43	**FIN DE L'ATTAQUE** • Durée totale : un heure et 47 minutes

	• Persistance : ACTIVE

V. Impact de la compromission

❖ Analyse d'Impact par Critère CIA

- Confidentialité compromise : Données exfiltrées (hachés de tous les mots de passe, liste complète des comptes et privilèges administratifs)
- Intégrité compromise : Modifications (Création compte backdoor "backup", Ajout de clés SSH non autorisées et logs système modifiés)
- Disponibilité a risque : Modifications (Contrôle root complet (déni de service possible), connexion C2 active (commandes à distance) et risque de ransomware ou sabotage)

❖ Indicateurs de Compromission (IOC)

- IOC Réseau : IP source 192.168.253.201 (machine attaquante), Port C2 4444/tcp (connexion sortante) et reverse shell actif
- IOC Système - Comptes : Compte compromis : testuser et compte backdoor : backup (uid=1003, groupe=sudo)

VI. RECOMMANDATIONS

❖ Actions Immédiates :

Les actions suivantes ont été effectuées dans le cadre de la réponse à incident :

- CONFINEMENT :

• IP attaquante bloquée (192.168.100.20) via UFW
• Connexion C2 terminée
• Compte backdoor supprimé

- ÉRADICATION :

• Fichiers malveillants supprimés (/tmp/exfil_*)
• Configuration sudo permissive supprimée

- RÉCUPÉRATION :

• Tous les mots de passe changés
• Sessions révoquées et système restauré

❖ Recommandations Court Terme

-Maintenir la surveillance intensive 48 heures
-Considérer la suppression du compte testuser (si non nécessaire)
-Audit de sécurité des autres systèmes
-Formation des utilisateurs sur les mots de passe forts

❖ Recommandations Moyen Terme

- Implémenter l'authentification multifacteur (2FA) pour SSH
- Déployer une solution SIEM (centralisation des logs)
- Automatiser les sauvegardes quotidiennes
- Politique de mots de passe stricte (14+ caractères)
- Révision complète des privilèges sudo

❖ Recommandations Long Terme

- Segmentation réseau (DMZ, VLANs)
- Système de détection/prévention d'intrusion (IDS/IPS)
- SOC ou service de monitoring 24/7
- Tests d'intrusion trimestriels
- Plan de réponse à incident formalisé